12.1.3. 의무기록/의료정보 접근권한

제 정 일	2010.10.	최 종 개 정 일	2025.03.25.	최 종 검 토 일	2025.03.25.
담 당 부 서	의무기록팀, 정보서비스팀				
유 관 부 서					

관 련 기 준	4주기 의료기관인증기준: 12.1 의료정보/의무기록 관리 JCI Standard 7th Edition: MOI.2, 2.1

제1조 (목적)

1. 진료서비스를 제공하는데 필요한 업무 목적별 접근권한을 규정하고, 접근절차를 제시함으로써 환자의 개인정보와 병원의 정보자산을 보호하는데 목적이 있다.

제2조 (정의)

1. 의무기록/의료정보 접근권한: 병원에 구축된 정보자산을 이용함에 있어 직종별 해당업무를 수행하기 위하여 조회, 입력, 출력 등의 행위를 할 수 있는 권한을 의미한다.

제3조 (절차)

1. 관리부서
   1) 접근권한의 전반적 관리는 의무기록팀과 디지털헬스실이 관리한다.
   2) 부서 내 직원의 업무별 접근권한은 부서장이 관리한다.

2. 적용대상 및 범위
   1) 적용대상: 업무상 의무기록정보 접근이 필요한 자
   2) 적용범위: 의무기록정보에 접근하는 모든 시스템에 적용한다.

3. 접근권한 부여: 전자 의무기록, 영상 의무기록, 전자화된 환자정보(OCS(Order Communication System), PACS(Picture Archiving and Communication System), 검사결과지 등)는 직종별, 목적별, 부서별, 업무별, 서식별 등으로 분류하여 조회(열람), 입력(수정 포함), 출력, 삭제로 차등 부여한다.
   1) 교수
      (1) 소속과의 본인 진료 환자와 협진의뢰 받은 환자에 대해 조회, 입력, 삭제(본인이 작성한 기록으로 제한) 권한을 가진다.(처방입력 권한을 포함한다.) 단, 완결된 의무기록과 사본 발급이 완료된 기록에 대한 수정 및 삭제 절차는 세브란스병원 내규 [12.1.2. 환자정보 및 의무기록 정정]에 따른다.
      (2) 타과 및 본인 진료 환자가 아닌 환자에 대한 접근 시에는 접근 사유를 필수로 입력해야 조회할 수 있다.
   2) 전공의(레지던트, 인턴)
      (1) 소속과의 환자와 협진의뢰 받은 환자에 대해 조회, 입력, 삭제(본인이 작성한

기록으로 제한) 권한을 가진다. (처방입력 권한을 포함한다.) 단, 완결된 의무기록과 사본 발급이 완료된 기록에 대한 수정 및 삭제 절차는 세브란스병원 내규 [12.1.2. 환자정보 및 의무기록 정정]에 따른다.

(2) 타과 및 담당환자가 아닌 환자에 대한 접근 시에는 접근 사유를 필수로 입력해야 조회할 수 있다.

(3) 교육수련부에서 기간별 소속과 정보를 등록 및 관리한다.

3) 강사: 전공의와 동일한 권한을 가진다. (처방입력 권한을 포함한다.)

4) 간호사

(1) 간호사는 소속부서 혹은 담당환자에 대해, 업무기간 동안 환자기록을 조회하고 입력, 삭제(본인이 작성한 기록으로 제한) 할 수 있는 권한을 가진다.

(2) 진료지원간호사는 세브란스병원 지침에 따라 업무 범위에 해당하는 기록에 한해 초안 작성 및 오입력에 대해 수정을 할 수 있으며 이에 대해서는 주치의(담당교수)가 최종 확인 및 전자서명 한다.

(3) 환자의 부서이동 또는 퇴원 후에는 접근 사유를 남기고 접근하며 조회, 입력, 삭제(본인이 작성한 기록으로 제한) 할 수 있다. 단, 완결된 의무기록과 사본 발급이 완료된 기록에 대한 수정 및 삭제 절차는 세브란스병원 내규 [12.1.2. 환자정보 및 의무기록 정정]을 따른다.

(4) 환자 퇴원 시 진료연속성을 위하여 퇴원요약지 사본을 출력하여 환자에게 제공한다.

(5) 응급진료센터 간호사는 응급 전원 환자에 한해 사본 발급 처방에 따라 의무기록을 출력하여 환자에게 제공할 수 있다.

5) 의료기술직(기사, 약사, 영양사, 사회사업사, 언어치료사, 보험심사자, 보건의료정보관리사 등)

(1) 물리치료사, 작업치료사, 재활심리사, 영양사, 사회사업사, 언어치료사는 치료 상담을 의뢰받은 환자에 대해 해당 서식 범위 내에서 조회, 입력, 삭제(본인이 작성한 기록으로 제한) 권한을 가진다.

(2) 약사는 처방감사, 복약상담을 의뢰받은 환자에 대해, 해당부서 서식 범위 내에서 조회, 입력, 삭제(본인이 작성한 기록으로 제한) 권한을 가진다. 투약관리를 위해 투약기록을 조회할 수 있다.

(3) 보험심사자는 심사담당과의 환자에 한해 조회, 출력 권한을 가진다.

(4) 보건의료정보관리사와 사본발급 담당자는 미비기록관리 대상 환자와 사본발급 대상자에 대해 해당 서식을 조회, 출력할 수 있다.

6) 임상연구자는 환자별 접근권한을 신청하여 승인을 득해야 접근이 가능하다.

7) 원무팀 사무직원은 원무관련 업무에 한하여 조회와 출력 권한을 가진다.

8) 실습학생은 실습에 관계된 일부 환자에 대해 실습기간 중 조회 권한을 가진다.

9) 진료협력센터 직원은 진료협력센터업무와 관련한 기록을 입력, 조회, 출력, 삭제(본인이 작성한 기록으로 제한) 권한을 가진다.

10) 임상연구 코디네이터(CRC, Clinical Research Coordinator): 해당 연구 과제에 한하여 의무기록 조회 권한을 가진다.

11) 전사업무담당자는 전사 업무와 관련된 기록에 한하여 입력, 조회 권한을 가진다. 단 기록 입력 시 임시저장만 가능하며 해당 업무에 책임이 있는 의사가 최종 확인 및

전자서명 한다.

12) 진료용 이외의 목적으로 신청할 경우에는 조회사유를 입력 후 조회가 가능하며, 연구용 및 집담회용으로 신청할 경우에는 권한관리자는 신청자, 신청용도, 신청목적, 열람기간 등을 확인하여 2주간의 열람기간 동안 승인한다.

4. 모니터링

1) 접근권한 적절성 모니터링: 의무기록의 손상, 분실, 도난, 유출, 변조를 예방하기 위하여 업무수행에 필요한 최소한의 범위로 권한을 부여하고 의무기록 접근권한 적절성을 주기적(년 1회)으로 모니터링 및 관리한다.
2) 접속기록 모니터링: 접속기록은 2년 이상 안전하게 보관하며, 월 1회 이상 점검한다.
3) 열람이력 모니터링: 누가, 언제, 어떤 기록을 열람했는지 확인 가능하도록 기록 열람 이력을 남기고 모니터링 한다.

5. 접근권한 재검토

1) 사용자의 프로그램 접근권한은 주기적으로 검토되어야 한다.
2) 사용자별 특별권한을 부여한 계정에 대해 주기적인 계정검토 작업이 이루어져야 한다.
3) 계정사용 등록 및 해지 신청에 의거 허가되지 않는 계정을 주기적으로 검토한다.
4) 사용자의 접근권한(권한변경, 말소)에 대한 기록은 3년간 보관해야 한다.

6. 인사이동 시 접근권한 관리

1) 신규직원은 인사정보 입력 시 접근권한을 부여하거나 발령부서 부서장이 확인 후 부여한다.
2) 사용자 접근권한은 동일 사용자가 같은 조직 내에서 다른 곳으로 이동한 경우 즉시 변경되어야 한다.
3) 퇴직정보가 입력되면 접근권한은 자동 해지된다.
4) 전보, 휴직, 퇴직 등 인사변동 발생 시 자동 접근통제 되며, 재할당 또는 유효일자 조정을 시행한다.
5) 부서이동 발령 시 발령 받은 부서의 부서장이 권한을 재부여한다.

7. 의료정보와 의무기록 관련 직원 채용 및 외부 계약 시에는 정보보호 및 보안을 위한 적절한 신원검증을 하고 정보 보호 서약서 및 필요시 개인정보 처리 위탁 계약서를 작성한다.

8. 보안관리

1) 의료정보시스템 사용자는 개인별 ID와 비밀번호를 부여하며, 신원확인을 위한 공인인증서 등의 인증시스템을 추가 적용한다.
2) 전자 의무기록에 사용되는 공인인증서명은 1년 단위 갱신 관리한다.
3) 사용자 계정관리(사용자의 ID와 비밀번호 사용원칙)
   (1) 비밀번호는 다음 문자 종류 중 2종류 이상을 조합하여 최소 10자리 이상 또는 3종류 이상을 조합하여 최소 8자리 이상의 길이로 구성해야 한다.
      ① 영문 대문자 – 26개
      ② 영문 소문자 – 26개

③ 숫자 – 10개

④ 특수문자 – 32개

(2) 비밀번호는 연속적인 숫자나 생일, 전화번호 등 추측하기 쉬운 숫자의 사용을 금하며, 신규 비밀번호 설정 시 이전 4회의 비밀번호는 사용할 수 없다.

(3) 비밀번호는 90일에 1회 이상 반드시 변경해야 한다.

(4) 비밀번호 입력 시 5회 이상 오류가 발생한 경우, 안전한 본인 인증 수단을 통하여 비밀번호를 재설정하도록 한다.

4) 병원정보시스템은 일정시간 이상 키보드나 마우스 조작이 없을 때 자동 로그아웃되어 부정한 정보 노출을 방지한다.

9. 특별 접근권한 관리

1) 환자가 개인정보보호 요청을 한 경우 또는 병원에서 환자의 개인정보보호를 위해 접근권한 관리가 필요하다고 판단된 경우에는 특별 접근권한 관리 대상으로 등록하여 관리한다.

2) 기본적으로는 주치의(담당교수)가 환자의 접근권한을 부여 및 해제한다.

3) 주치의(담당교수) 부재 또는 필요 시 병원장, 디지털헬스실장, 의무기록팀장은 권한을 대행할 수 있다.

10. 의료정보 및 시스템 기능에 대한 접근은 다음의 접근통제정책에 따라 제한한다.

1) 의료정보시스템 접근을 통제하기 위한 관리적 기능을 마련한다. (사용자 계정에 대한 프로그램 접근권한 부여/제거 등)

2) 자료의 읽기, 쓰기, 삭제, 출력 등의 권한은 사용자별 할당된 업무분장과 보안수준에 따라 부여한다.

3) 다른 응용프로그램에서 접근이 허용되지 않는 프로그램으로 강제적으로 이동하여 실행하는 것 등을 제한한다.

11. 책임: EMR(Electronic Medical Record) 접속이력관리에서 허용된 조회사유 이외에 EMR을 접속하는 경우, 정보유출이 의심되지 않는다면 권고를 통해 재발되지 않도록 교육하며, 사안에 따라 의무기록위원회(또는 개인정보보호위원회)의 안건 상정으로 심의 후 징계위원회에 회부하여 징계할 수 있다.

제4조 (부록)

1. 직종, 부서(업무), 서식별 의무기록/의료정보 접근권한

제5조 (참고)

1. 의료법 제21조
2. 개인정보보호법

내규의 제·개정 이력

제1조 (내규의 제정 및 시행)

1. 이 내규는 2010년 10월부터 시행한다.

제2조 (내규의 전면개정 및 시행)

1. 이 내규는 2025년 3월 25일부터 시행한다.

제3조 (내규의 개정)

승 인: 세브란스병원장 이 강 영 (인)